

Guía de implementación del Marco de ciberseguridad 5.0

OR.2 Conformar un Comité de Seguridad de la Información

Requisito OR.2	Conformar un Comité de Seguridad de la Información
Objetivo	Contar con un equipo de personas con capacidad de decisión sobre los objetivos de la organización, que vele por la seguridad de la información, marque los lineamientos estratégicos en la materia y defina los objetivos anuales.
Controles	Nivel 1 - OR.2-1: se encuentra designado formalmente el CSI de la organización. Nivel 2 - OR.2-2: el CSI se reúne periódicamente y documenta dichas reuniones. Nivel 3 - OR.2-3: las responsabilidades y atribuciones del CSI están documentadas y aprobadas por la Dirección. - OR.2-4: el CSI tiene establecidas pautas para su funcionamiento. - OR.2-5: el CSI participa en la definición de niveles aceptables de riesgo y en la aprobación del plan de tratamiento de riesgos. Nivel 4 - OR.2-6: el CSI revisa los planes y políticas de seguridad y aprueba sus actualizaciones. - OR.2-7: el CSI aprueba la planificación estratégica de seguridad. - OR.2-8: el CSI revisa los indicadores asociados a los planes anuales de mejora de seguridad de la información.

Requisito OR.2	Conformar un Comité de Seguridad de la Información
Guía de implementación	Comité de Seguridad de la Información Se debe designar los integrantes del Comité de Seguridad de la Información (CSI). El CSI debe estar formado por representantes de todas las direcciones o gerencias de la organización incluyendo responsable de TI. Dependiendo de la realidad y tamaño de la organización, los cometidos del CSI podrían incluirse a otros grupos ya existentes como por ejemplo el "Gabinete ministerial" o la reunión "Gerencial". Conformación En términos generales, su conformación refiere a directivos con toma de decisiones dentro de la organización. Si la organización pertenece a la Administración Central y el CSI está formado a nivel del inciso, su conformación es con los directores de las unidades ejecutoras. Si está formado a nivel de unidad ejecutora, se conforma con los directores de área. Esta situación también podría darse en otros escenarios, por ejemplo, en el ámbito privado con casa matriz y sucursales. Funcionamiento El CSI se debe reunir periódicamente. Cuando el CSI se reúna con el propósito de revisar temas referentes a la evaluación y tratamiento del riesgo de seguridad de la información, se debe incluir la participación del responsable de la Gestión de Riesgos. El CSI puede convocar a sus reuniones a otros expertos que considere pertinentes para el cumplimiento de sus cometidos. Cometidos Dentro de los principales cometidos del CSI se encuentran: • Establecer y aprobar sus pautas de funcionamiento. • Promover, difundir y apoyar la seguridad de la información, garantizando que sea parte de los procesos de planificación. • Definir las estrategias de seguridad de la información transversales a la organización. • Aprobar los planes, políticas y todo aquello que incremente y mejore la seguridad de la información. • Dar cuenta a la Dirección de la organización respecto a la no aprobación y/o no cumplimiento de las decisiones adoptadas por el referido Comité. • Establecer los niveles aceptables de riesgo.
Instituciones de salud	Además de lo planteado en términos generales, el CSI debe contar con al menos un miembro perteneciente al área asistencial.
Instituciones Emisoras de Dinero Electrónico (IEDE)	No aplica

Requisito OR.2	Conformar un Comité de Seguridad de la Información
Guía de evidencia para auditoría	• Resolución de la creación del CSI, u otro mecanismo o registros que evidencie su creación. • Responsabilidades del CSI aprobados por la Dirección. • Pautas de funcionamiento del CSI. • Registro de las reuniones mantenidas por el CSI durante el período auditado (actas, orden del día, correos, otros). • Registro de evaluaciones del funcionamiento del CSI. • Registro de aprobaciones de políticas y modificaciones de políticas por el CSI (minutas, actas, correos, formularios, otros). • Plan de tratamiento de riesgos aprobado por el CSI.
Normativa asociada	No aplica

← [OR.1 Designar un Responsable de la Seguridad de la Información](#)

[OR.3 Definir los mecanismos para el contacto formal con autoridades y equipo de respuesta](#) →

[Ir al Índice](#)

Etiquetas

[Gestión y auditoría de Seguridad de la Información](#)

[Marco de Referencia](#)

[Política Digital del Uruguay](#)

[Políticas de Ciberseguridad](#)

[Ciberseguridad](#)

[Herramientas para la ciudadanía](#)

[Herramientas para organismos](#)

[Política Digital del Uruguay](#)

Índice

[Introducción](#)

[Objetivo y Alcance](#)

[Requisitos](#)

[Organización y Gobernanza](#)

[Gestión de Riesgos](#)

[Gestión humana](#)

[Gestión de activos](#)

[Control de acceso](#)

[Seguridad física y del ambiente](#)[Seguridad de las operaciones](#)[Seguridad de las comunicaciones](#)[Adquisición, desarrollo y mantenimiento de los sistemas](#)[Relación con proveedores](#)[Gestión de incidentes](#)[Continuidad de las operaciones](#)[Cumplimiento normativo y revisión](#)[Protección de datos personales](#)

Agencia de Gobierno Electrónico y Sociedad de la Información y del Conocimiento

Dirección: Liniers 1324 piso 4 (Montevideo, Uruguay)

Teléfono: [\(+598\) 2901 2929](tel:+59829012929)

[Contacto](#)

Horario de atención: lunes a viernes de 9:00 a 17:00 h.

gub.uy